

HIPAA Gap Assessment

Comprehensive vendor-verified compliance review · Version 6.0

PREPARED FOR	SCOPE	STANDARDS	AUDIENCE
Kiem Vukadinovic, NP · Founder & Privacy Officer	All PHI systems, edge functions, third-party vendors	HIPAA Security & Privacy Rules · CA CMIA	Development & operations team

1. Executive Summary

Radiantlyk Aesthetic operates a HIPAA-covered medical aesthetics practice with a custom-built Lovable Cloud application handling clinical charting, GFes, consents, PROMs, appointment scheduling, checkout, and internal messaging. This assessment is based on a code-level audit of every deployed edge function and integration.

The application layer is fundamentally sound: TLS in transit, Postgres encryption at rest, Row-Level Security on every PHI table, role-based access, break-glass audit, and a dedicated `phi_access_log`. The remaining risk is concentrated in three areas: (1) unsigned/unverified Business Associate Agreements with third-party vendors, (2) missing administrative safeguards (formal risk analysis approval, MFA enforcement, idle-timeout config), and (3) one production edge function currently routing PHI through a non-BAA channel.

Overall posture: Technically strong, administratively incomplete. 3 Critical, 6 High, 5 Medium, 2 Low findings identified. No evidence of a reportable breach.

Vendor inventory (verified from source code)

VENDOR	FUNCTION	PHI TOUCHED	BAA STATUS
Lovable Cloud	DB, auth, storage, edge functions	All clinical & billing PHI	COVERED
Lovable Emails (notify.bookrka.com)	Transactional email (confirmations,	Name, appt time, service, receipt	COVERED

VENDOR	FUNCTION	PHI TOUCHED	BAA STATUS
	receipts, OTP, consent links)		
GoHighLevel	SMS reminders, two-way SMS, CRM sync	Name, appt time, service, phone	UNVERIFIED
Brevo	Marketing campaigns + 1 internal VO alert	Marketing: no PHI · VO alert: client name/region	NONE
Stripe	Card processing, terminal, receipts	Payment metadata linked to patient	STANDARD BAA AVAILABLE
Affirm	Financing (checkout links)	Name, amount, email	VERIFY
Google Workspace	Staff calendar, staff email	Appointment metadata on staff calendar	CLICK-ACCEPT IN ADMIN
Cloudflare	DNS, WAF, TLS termination	Encrypted in transit only	ENTERPRISE BAA
OpenAI / Google (via Lovable AI Gateway)	AI Scribe transcription, note drafting	Visit audio & transcript	COVERED UNDER LOVABLE

Findings at a glance

ID	SEVERITY	TITLE	HIPAA §
F-01	CRITICAL	GoHighLevel BAA unverified — SMS carries appointment PHI	§164.308(b)
F-02	CRITICAL	VO on-call alert routes PHI through Brevo (no BAA)	§164.308(b)
F-03	CRITICAL	Risk Analysis template not populated / approved	§164.308(a)(1)(ii)(A)
F-04	HIGH	MFA available but not enforced for admin/NP/provider roles	§164.312(d)
F-05	HIGH	Idle-session auto-logout hook exists but is not wired	§164.312(a)(2)(iii)

ID	SEVERITY	TITLE	HIPAA §
F-06	HIGH	PHI access log retention policy not documented (6-year rule)	§164.312(b), §164.316(b)(2)
F-07	HIGH	Incident-response runbook not published (breach UI exists)	§164.308(a)(6)
F-08	HIGH	Backup restore drills undocumented	§164.308(a)(7)(ii)(D)
F-09	HIGH	Workforce sanctions policy not signed by staff	§164.308(a)(1)(ii)(C)
F-10	MEDIUM	Google Workspace BAA not click-accepted in Admin console	§164.308(b)
F-11	MEDIUM	Annual HIPAA training register not populated for 2026	§164.308(a)(5)
F-12	MEDIUM	Device & media inventory (staff phones/tablets) not tracked	§164.310(d)
F-13	MEDIUM	Audit log review cadence not scheduled	§164.308(a)(1)(ii)(D)
F-14	MEDIUM	Notice of Privacy Practices acknowledgement not required at intake	§164.520(c)
F-15	LOW	Business continuity / disaster recovery plan not written	§164.308(a)(7)
F-16	LOW	Vendor annual re-review cadence not scheduled	§164.308(b)(1)

2. Scope & Methodology

In scope: Radiantlyk Aesthetic's production application (booking, clinical, checkout, admin), every deployed Supabase Edge Function, and every third-party vendor referenced in the codebase.

Methodology:

- Source-code review of all edge functions under supabase/functions/, including transactional email, SMS, GHSL sync, checkout, and safety alerts.
- Database schema and RLS policy review across 110+ tables.
- Vendor identification by grepping every outbound HTTP call and API key reference.
- Mapping each control to HIPAA Security Rule §164.308–316 and California CMIA (Civ. Code §56 et seq.).

Confirmed by user (Kiem Vukadinovic): Brevo is marketing-only; GoHighLevel handles SMS; Lovable Emails handles all client-facing transactional email; no separate hosting/receipt vendor is used.

3. PHI Data Flow Map

1. **Intake & booking** — Client submits intake and books appointment → written to appointments, client_intake_submissions, client_profiles. Confirmation email & receipt sent via Lovable Emails (BAA-covered).
2. **Reminders** — Appointment reminders sent via GoHighLevel SMS. *PHI = name + appointment time + service.*
3. **Clinical visit** — GFE, consents, chart notes, photos captured. Photos in Lovable Cloud Storage; charts in Postgres with RLS.
4. **AI Scribe (optional)** — Visit audio uploaded to Lovable Cloud Storage → transcribed via Lovable AI Gateway → auto-deleted after 30 days.
5. **Safety alerts** — VO protocol triggers an internal email to on-call NPs. **Currently routed through Brevo — this is F-02.**
6. **Checkout** — Stripe (card + terminal). Receipt via Lovable Emails.
7. **Marketing** — Brevo campaigns to opted-in subscribers. No PHI in payload; segmentation by treatment category is generic.

4. Detailed Findings

F-01 • GoHighLevel BAA unverified

CRITICAL

HIPAA §164.308(b)(1) Business Associate Contracts • CMIA §56.10

RISK Every appointment reminder, no-show follow-up, and two-way SMS conversation includes patient name, appointment time, and service booked — this is PHI. Without an executed BAA and confirmation of GHL's HIPAA-compliant plan, this is a reportable disclosure to an unauthorized business associate.

EVIDENCE ghl-reminder-send, ghl-sms-send, ghl-sms-inbound, ghl-sync-* functions call GHL's API with PHI in message bodies.

REMEDIATION Confirm the workspace is on GHL's HIPAA-compliant plan and request/execute their BAA. See companion document *BAA Acquisition Guide*. Until confirmed, restrict SMS content to "Radiantlyk: Your appointment is confirmed" without patient name or service.

F-02 • VO on-call alert routes PHI through Brevo

CRITICAL

HIPAA §164.308(b)(1) • §164.502(e)

RISK The vo-alert-oncall edge function sends an email containing client name, region, and product to on-call nurse practitioners via Brevo (marketing platform, no BAA). This is PHI leaving the covered entity through a non-BA channel.

EVIDENCE supabase/functions/vo-alert-oncall/index.ts — POSTs to connector-gateway.lovable.dev/brevo/smtp/email with client_name and region in the HTML body.

REMEDIATION Reroute this single function to Lovable Emails (BAA-covered). Estimated developer effort: 15 minutes. This is the fastest critical win.

F-03 • Risk Analysis template not populated or approved

CRITICAL

HIPAA §164.308(a)(1)(ii)(A)

RISK The Security Rule's foundational requirement is a documented risk analysis. The HIPAA policy templates now live in /staff/hipaa-policies, but the Risk Analysis template is empty and unsigned. Without it, no downstream safeguard is defensible in an audit.

REMEDIATION Populate the Risk Analysis template using the findings from this document, obtain Privacy Officer approval, and mark the policy version approved in the app.

F-04 · MFA available but not enforced for privileged roles

HIGH

HIPAA §164.312(d) Person or entity authentication

RISK Lovable Cloud MFA is available and `/staff/mfa` exists, but there is no gate blocking admin, nurse_practitioner, or provider roles from accessing clinical routes without enrolling MFA. Password-only access to PHI is not defensible.

REMEDIATION Add a 14-day grace-period MFA enrollment gate in `StaffLayout`. Block clinical routes for privileged roles that have not enrolled after grace period.

F-05 · Idle-session auto-logout not wired

HIGH

HIPAA §164.312(a)(2)(iii) Automatic logoff

RISK `useIdleLogout` hook exists but is not mounted in the staff shell. An unattended workstation stays authenticated indefinitely.

REMEDIATION Mount the hook in `StaffLayout` with a 15-minute idle timeout and a 60-second warning modal.

F-06 · PHI access log retention not documented

HIGH

HIPAA §164.312(b) Audit controls · §164.316(b)(2) 6-year retention

RISK `phi_access_log` and `clinical_audit_log` capture reads/writes, but there is no documented retention SLA. HIPAA requires 6 years.

REMEDIATION Document a 6-year retention policy in the HIPAA policy pack. Add a scheduled job that archives (not deletes) logs older than 90 days to cold storage.

F-07 · Incident-response runbook not published

HIGH

HIPAA §164.308(a)(6) Security incident procedures · CMIA §56.36

RISK The `/staff/breach` UI exists to file breach reports, but the underlying runbook (who to call, when to notify OCR, when to notify the California AG, patient-notification templates) is not written. CMIA requires notification to affected patients **AND** the California AG within **15 BUSINESS DAYS** of discovery — stricter than federal HIPAA's 60 days.

REMEDIATION Populate the "Security Incident Response" policy template with a step-by-step runbook. Include the CMIA 15-day countdown as an automated timer in `breach_reports`.

F-08 · Backup restore drills undocumented

HIGH

HIPAA §164.308(a)(7)(ii)(D) Testing and revision procedures

RISK Supabase Point-in-Time Recovery is enabled, but no restore drill has been performed and documented. A backup that has never been restored is not a backup.

REMEDIATION Perform a quarterly restore drill to a staging environment. Document the RTO/RPO and file in the Contingency Plan policy.

F-09 · Workforce sanctions policy not signed

HIGH

HIPAA §164.308(a)(1)(ii)(C) Sanction policy

RISK The Sanctions policy template exists but has not been signed by workforce members. Enforcement of PHI-handling violations is not documented.

REMEDIATION Push the sanctions policy through /staff/compliance assignment flow. Require signature at hire and annually.

F-10 · Google Workspace BAA not click-accepted

MEDIUM

HIPAA §164.308(b)(1)

RISK Staff calendar events created via google-calendar-* functions store appointment metadata (patient name + time) on Google Calendar. Google offers a click-accept BAA in the Workspace Admin console under Account > Legal & compliance > Security and privacy additional terms.

REMEDIATION Log in as Workspace superadmin and accept the BAA. Store the acceptance timestamp in vendors.

F-11 · 2026 HIPAA training register empty

MEDIUM

HIPAA §164.308(a)(5)

REMEDIATION Assign the "Annual HIPAA Awareness" compliance protocol to every workforce member with a 30-day due date. The compliance module already tracks completion.

F-12 · Device & media inventory not tracked

MEDIUM

HIPAA §164.310(d) Device and media controls

REMEDIATION Add a device inventory (staff phones, iPads, laptops) with owner, serial, encryption state, and disposal date. Require full-disk encryption and screen-lock on every device that touches PHI.

F-13 · Audit log review cadence not scheduled

MEDIUM

HIPAA §164.308(a)(1)(ii)(D)

REMEDIATION Set a monthly recurring task for the Privacy Officer to review phi_access_log anomalies via /staff/audit-report. Document findings.

F-14 · Notice of Privacy Practices acknowledgement not required at intake

MEDIUM

HIPAA §164.520(c)

REMEDIATION Add an NPP acknowledgement checkbox to ClientIntake.tsx. Store npp_acknowledged_at on the intake submission.

F-15 · Business continuity plan not written

LOW

HIPAA §164.308(a)(7)

REMEDIATION Draft a one-page BC/DR document covering: primary/backup providers, contact tree, degraded-mode SMS scripts, paper-chart fallback, and RTO/RPO targets.

F-16 · Vendor annual re-review cadence not scheduled

LOW

HIPAA §164.308(b)(1)

REMEDIATION Add a yearly recurring review of every vendor's BAA and security posture on the /staff/vendors page.

5. HIPAA Security Rule Compliance Matrix

STANDARD	IMPLEMENTATION	STATUS	RELATED
§164.308(a)(1) Security Management	Risk analysis template, risk mgmt policy, sanctions, activity review	PARTIAL	F-03, F-06, F-09
§164.308(a)(2) Assigned Responsibility	Kiem Vukadinovic = Privacy & Security Officer (document formally)	GAP	—
§164.308(a)(3) Workforce Security	user_roles + has_role(); onboarding/termination checklist needed	PARTIAL	F-04
§164.308(a)(4) Info Access Mgmt	RLS + role-based policies enforced on every PHI table	COMPLIANT	—
§164.308(a)(5) Awareness & Training	Compliance module exists; 2026 register empty	GAP	F-11
§164.308(a)(6) Incident Procedures	Breach report UI present; runbook missing	PARTIAL	F-07
§164.308(a)(7) Contingency Plan	Lovable Cloud PITR + daily backup; drill undocumented	PARTIAL	F-08, F-15
§164.308(b) Business Associate Contracts	BAAs pending/unverified with GHL, Brevo, Affirm	GAP	F-01, F-02
§164.310(a) Facility Access	Cloud-hosted; physical clinic controls maintained separately	INFO	—
§164.310(d) Device & Media Controls	No device inventory yet	GAP	F-12
§164.312(a) Access Control	Auth + RLS + break-glass; idle timeout not wired	PARTIAL	F-05
§164.312(b) Audit Controls	phi_access_log + clinical_audit_log; retention undocumented	PARTIAL	F-06, F-13
§164.312(c) Integrity	Postgres constraints + audit triggers	COMPLIANT	—
§164.312(d) Person Authentication	Email+password + MFA available; MFA not enforced	PARTIAL	F-04

STANDARD	IMPLEMENTATION	STATUS	RELATED
§164.312(e) Transmission Security	TLS 1.2+ everywhere via Cloudflare + Lovable Cloud	COMPLIANT	—
§164.316 Documentation	Policy templates exist; approvals pending	PARTIAL	F-03

6. California CMIA Addendum

CMIA (Cal. Civ. Code §56 et seq.) applies to Radiantlyk as a California-licensed medical provider and is stricter than federal HIPAA in three ways:

1. **Breach notification within 15 business days** — Affected patients *and* the California Attorney General must be notified within 15 business days of discovery, versus HIPAA's 60 days.
2. **Patient access requests** — Records must be made available for inspection within **15 days** and copies delivered within **30 days**.
3. **Marketing authorization** — Explicit written authorization is required for any marketing use of PHI beyond direct treatment reminders.

Recommendation: Encode these SLAs as automated countdown timers on `breach_reports` and `phi_deletion_requests`. Gate `marketing_campaigns.send` on a valid `marketing_consent_at` flag on `newsletter_subscribers`.

7. Remediation Roadmap

Phase 1 — Critical (this week)

- F-02: Reroute vo-alert-oncall from Brevo to Lovable Emails (~15 min).
- F-01: Contact GoHighLevel; upgrade to HIPAA plan and execute BAA (see companion *BAA Acquisition Guide*).
- F-03: Populate and approve the Risk Analysis policy in /staff/hipaa-policies.

Phase 2 — High (next 2 weeks)

- F-04: Enforce MFA gate for admin/NP/provider roles in StaffLayout.
- F-05: Wire useIdleLogout with 15-min timeout + warning modal.
- F-07: Publish incident-response runbook with CMIA 15-day countdown.
- F-08: Perform and document backup restore drill.
- F-09: Push sanctions policy through compliance signature flow.
- F-06: Document 6-year retention and add cold-archive job for logs > 90 days.

Phase 3 — Medium (next 30 days)

- F-10: Accept Google Workspace BAA in Admin console.
- F-11: Assign 2026 HIPAA Awareness training to every workforce member.
- F-12: Build device & media inventory in /staff/vendors or a new page.
- F-13: Schedule monthly audit-log review.
- F-14: Add NPP acknowledgement checkbox to client intake.

Phase 4 — Low (next quarter)

- F-15: Draft one-page BC/DR plan.
- F-16: Add annual vendor re-review reminders.

8. Sign-off

Privacy Officer:	Kiem Vukadinovic, NP	Medical Director:	Dr. Aloysius N. Fobi, MD
Assessment version:	6.0	Assessment date:	July 4, 2026
Next review:	October 4, 2026	Classification:	Confidential — Internal Use

This assessment is a technical and administrative gap review for internal remediation planning. It is not legal advice and is not a formal certification. Formal HIPAA/CMIA compliance attestation requires review by qualified privacy counsel and,

where applicable, third-party auditors.